

Contraintes & « grain » RGPD : à quel niveau Merise ?

MediPlan — document explicatif (préparation du schema.sql) · 17/06/2026

Une question revient souvent : les contraintes techniques (UUID, ON DELETE, CHECK...) et les éléments RGPD (anonymisation, journalisation...), à **quelle étape les introduit-on ?** Réponse : presque tout se matérialise au **niveau physique (MPD)**, c'est-à-dire dans le `schema.sql`. Mais certaines contraintes **découlent directement du MCD** (des cardinalités) : elles naissent au conceptuel et ne font que s'écrire au physique. Bien distinguer les deux, c'est ce qui fait un schéma maîtrisé plutôt que générique.

Rappel des trois niveaux : **MCD** conceptuel (entités, associations, cardinalités) · **MLD** logique (tables, clés étrangères) · **MPD** physique (types, contraintes SQL, index) = le `schema.sql`.

1. Ce qui naît au MCD et s'écrit au physique

Ces contraintes ne sont pas arbitraires : elles traduisent en SQL une décision déjà prise via les cardinalités.

Contrainte SQL	Origine	Exemple MediPlan
NOT NULL	Cardinalité minimale = 1 MCD	<code>rendez_vous</code> participe (1,1) à <i>prendre</i> → un RDV a obligatoirement un patient → <code>patient_id</code> NOT NULL
UNIQUE	Cardinalité maximale = 1 MCD	Côté créneau, <i>occuper</i> est (0,1) → un créneau réservé une seule fois → <code>creneau_id</code> UNIQUE dans <code>rendez_vous</code>

On peut donc **tracer** la règle métier du MCD jusqu'au mot-clé SQL — un argument fort en soutenance.

2. Ce qui est purement physique (aucune trace au MCD/MLD)

Élément	Rôle	Décision
Type UUID des PK	Identifiant non devinable (vs SERIAL séquentiel)	Sécurité — limite l'énumération d'IDs (lien EBIOS R4 / IDOR)
Règles ON DELETE	Comportement quand on supprime une ligne référencée	RESTRICT / SET NULL / CASCADE selon la table
Contraintes CHECK	Borne le domaine de valeurs	Statut RDV ∈ {planifié, confirmé, annulé, honoré}
Timestamps	Traçabilité technique	<code>created_at</code> , <code>updated_at</code>

3. Le « grain » RGPD : deux cas à ne pas confondre

Déjà conceptuel — la table `consentement` est une *entité métier* : elle figure dans ton MCD et ton MLD. Rien à « rajouter » au physique sinon ses contraintes habituelles.

Introduit au physique (sécurité) — trois éléments ont été *volontairement écartés* du MCD car ce sont des mécanismes techniques, et ils réapparaissent dans le `schema.sql` :

Élément	But	Lien EBIOS
<code>dossier_medical</code> (table séparée, 1:1 patient)	Cloisonner les données de santé : accès restreint, chiffrement dédié	R1 — fuite de données

<code>journal_acces</code> (audit, écriture seule)	Tracer qui accède à quoi et quand	R1, R2 — compromission de compte
Champ d'anonymisation (<code>anonymise</code> , <code>anonymise_at</code>)	Droit à l'oubli : pseudonymiser plutôt que supprimer (préserve l'intégrité des RDV/audit liés)	R5 — conformité RGPD/HDS

Conséquence à assumer : le `schema.sql` comptera **12 tables** là où le MLD en a 10. C'est normal et défendable — ce sont des raffinements de sécurité dictés par l'analyse de risques, pas une incohérence. Il suffit de pouvoir l'expliquer : « ces deux tables et ce champ ne sont pas du métier, ce sont des réponses techniques aux risques R1, R2 et R5 ».

En résumé

Le MCD décide *le sens* (cardinalités → NOT NULL / UNIQUE) ; le MPD décide *la mécanique* (types, ON DELETE, CHECK, timestamps) et ajoute les *garde-fous de sécurité* (dossier cloisonné, audit, anonymisation) issus de l'EBIOS. Tout ceci constitue précisément le contenu du `schema.sql` — l'étape suivante.